

Báo cáo Tổng hợp Lỗi Phát hiện trên SUT EShop (Bug Report)

Hệ thống: EShop Backend (<http://localhost:3000>)

Sinh viên: Nguyễn Hiếu Thuận — MSSV: 23127125

1. BẢNG TỔNG HỢP 9 BUGS THỰC TẾ TRÊN SUT

STT	Mã Bug	Tính năng	Mức độ (Severity)	Tên Lỗi Kỹ Thuật	Test Cases phát hiện	GitHub Issue Link
1	BUG_FR06_01	FR-06	Medium	Trả về 200 OK body {} khi ID không tồn tại hoặc đã bị xóa	TC_FR06_ST_03, TC_FR06_DP_07	#2
2	BUG_FR06_02	FR-06	High (SEC-01/07)	Thiếu Input Validation trên Path :id, chấp nhận SQLi & chuỗi rác	TC_FR06_SEC_01, TC_FR06_DP_04	#3
3	BUG_FR06_03	FR-06	Medium	Sai kiểu dữ liệu trường price sản phẩm ID=2 (String thay vì Number)	TC_FR06_DP_02	#4
4	BUG_FR09_01	FR-09	High (SEC-02)	Auth Bypass — /api/apply-coupon không xác thực Bearer JWT (Vi phạm C4)	TC_FR09_COND_08, TC_FR09_SEC_02	#5
5	BUG_FR09_02	FR-09	Critical	Lỗi tính %: discount_amount = total * (1 - value) ra số âm và đội giá	TC_FR09_SCH_02	#6
6	BUG_FR09_03	FR-09	Medium	Lỗi biên C3: Đơn đúng bằng min_order_amount (300k) bị từ chối 400	TC_FR09_EXT_01, TC_FR09_EXT_05	#7
7	BUG_FR17_01	FR-17	Critical (OWASP A01)	Leo quyền RBAC — User thường tạo & xóa được mã giảm giá Admin	TC_FR17_SEC_01, TC_FR17_EXT_01	#8
8	BUG_FR17_02	FR-17	High (SEC-07)	Lỗi 500 & Rò rỉ lỗi CSDL SQLITE_CONSTRAINT khi tạo mã trùng code	TC_FR17_DP_04, TC_FR17_EXT_02	#9

STT	Mã Bug	Tính năng	Mức độ (Severity)	Tên Lỗi Kỹ Thuật	Test Cases phát hiện	GitHub Issue Link
9	BUG_FR17_03	FR-17	Medium	Thiếu Validation khi Tạo Mã Admin (cho phép giảm > 100%, min < 0)	TC_FR17_DP_05, TC_FR17_EXT_03	#10

2. CHI TIẾT CÁC LỖI & LIÊN KẾT GITHUB ISSUES

♦ Bug #1: BUG_FR06_01 — Trả về 200 OK body {} khi ID không tồn tại

- **Endpoint:** GET /api/products/:id
- **Severity:** Medium / REST Compliance
- **Mô tả ngắn:** Khi gọi GET /api/products/999999, hệ thống phản hồi 200 OK với body {} thay vì 404 Not Found.
- **Root Cause & Fix:** Trong server.js, thiếu kiểm tra if (!product) return res.status(404).json({ error: "Product not found" }).
- **GitHub Issue chi tiết:** Issue #2

Bug #2: BUG_FR06_02 — Thiếu Input Validation trên Path :id, chấp nhận SQLi

- **Endpoint:** GET /api/products/:id
- **Severity:** High / Security (SEC-01, SEC-07)
- **Mô tả ngắn:** Chấp nhận ID âm, ID chữ, SQL injection (1 OR 1=1) và trả về 200 OK thay vì từ chối 400 Bad Request.
- **Root Cause & Fix:** Thiếu middleware kiểm tra if (!Number.isInteger(Number(id)) || id <= 0) return res.status(400)....
- **GitHub Issue chi tiết:** Issue #3

Bug #3: BUG_FR06_03 — Sai lệch kiểu dữ liệu trường price của sản phẩm ID=2

- **Endpoint:** GET /api/products/2
- **Severity:** Medium / Schema Integrity
- **Mô tả ngắn:** Trường price trả về dạng chuỗi "28000000" thay vì kiểu số 28000000, làm gây schema validation.
- **Root Cause & Fix:** Seed data SQLite lưu dạng text. Cần đổi kiểu cột thành REAL hoặc ép kiểu Number(product.price).
- **GitHub Issue chi tiết:** Issue #4

Bug #4: BUG_FR09_01 — Lỗi hỏng Auth Bypass trên /api/apply-coupon

- **Endpoint:** POST /api/apply-coupon
- **Severity:** High / Security (SEC-02 Auth Bypass)
- **Mô tả ngắn:** Endpoint không kiểm tra Bearer JWT Token (Vi phạm điều kiện C4), cho phép khách vắng lai không đăng nhập áp mã thành công.

- **Root Cause & Fix:** Quên gắn middleware `authenticateToken` vào khai báo route `POST /api/apply-coupon`.
 - **GitHub Issue chi tiết:** [Issue #5](#)
-

Bug #5: `BUG_FR09_02` — Lỗi công thức tính giảm giá % cho kết quả âm

- **Endpoint:** `POST /api/apply-coupon`
 - **Severity:** `Critical / Business Logic Math Error`
 - **Mô tả ngắn:** Áp mã 10% cho đơn 500k tính ra `discount_amount = -4,500,000` và `final_amount = 5,000,000` (đội giá gấp 10 lần).
 - **Root Cause & Fix:** Công thức viết sai `(1 - coupon.discount_value)` thay vì `(coupon.discount_value / 100)`.
 - **GitHub Issue chi tiết:** [Issue #6](#)
-

Bug #6: `BUG_FR09_03` — Lỗi biên C3: Đơn bằng đúng `min_order_amount` bị từ chối 400

- **Endpoint:** `POST /api/apply-coupon`
 - **Severity:** `Medium / Boundary Logic Defect`
 - **Mô tả ngắn:** Đơn hàng đúng 300,000 đ áp mã `SAVE10` (min 300k) bị từ chối `400 Bad Request` do dùng toán tử `>` thay vì `>=`.
 - **Root Cause & Fix:** Sửa `if (total_amount > coupon.min_order_amount)` thành `if (total_amount >= coupon.min_order_amount)`.
 - **GitHub Issue chi tiết:** [Issue #7](#)
-

Bug #7: `BUG_FR17_01` — Lỗi hỏng Leo Quyền Phân Quyền (RBAC Privilege Escalation)

- **Endpoint:** `POST /api/admin/coupons, DELETE /api/admin/coupons/:id`
 - **Severity:** `Critical / Security (OWASP A01 Broken Access Control)`
 - **Mô tả ngắn:** Tài khoản User thường mang JWT Token vẫn gọi được API Admin tạo và xóa mã giảm giá thành công.
 - **Root Cause & Fix:** Route Admin chỉ check Token hợp lệ mà không check `req.user.role === 'admin'`. Cần thêm middleware `requireAdmin`.
 - **GitHub Issue chi tiết:** [Issue #8](#)
-

Bug #8: `BUG_FR17_02` — Lỗi 500 & Rò rỉ CSDL SQLite khi tạo mã trùng code

- **Endpoint:** `POST /api/admin/coupons`
 - **Severity:** `High / Security (SEC-07 Information Disclosure)`
 - **Mô tả ngắn:** Tạo mã trùng code `UNIQUE` ném lỗi `500 Internal Server Error` kèm chuỗi `SQLITE_CONSTRAINT: UNIQUE constraint failed`.
 - **Root Cause & Fix:** Bắt lỗi `err.message.includes('UNIQUE constraint')` và phản hồi mã `409 Conflict` hoặc `400 Bad Request`.
 - **GitHub Issue chi tiết:** [Issue #9](#)
-

Bug #9: `BUG_FR17_03` — Thiếu Input Validation khi Tạo Mã Giảm Giá Admin

- **Endpoint:** `POST /api/admin/coupons`
- **Severity:** `Medium / Data Integrity & Input Validation`
- **Mô tả ngắn:** Chấp nhận giảm giá > 100% (200%), ngưỡng đơn âm (-50k), lượt dùng âm (-5) và ngày hết hạn sai format ("`invalid_date`").
- **Root Cause & Fix:** Thiếu tầng kiểm thực schema body (Joi/Zod/express-validator) trước khi thực hiện câu lệnh `INSERT INTO coupons`.
- **GitHub Issue chi tiết:** [Issue #10](#)